AI-based re-Identification attacks - and how to protect against them

mostly.ai/blog/synthetic-data-protects-from-ai-based-re-identification-attacks

Michael Platzer April 22, 2022

A new, powerful breed of privacy attacks is emerging. One that uses AI to re-identify individuals based on their behavioral patterns. This advent has broad implications for organizations, both from compliance as well as from a risk perspective, as legacy anonymization measures are highly vulnerable. And it's these risks that drive the surge in demand for privacy-preserving synthetic data, enabled by MOSTLY AI, as a safe and future-proof alternative - even against AI-based re-identification attacks.

The ineffectiveness of data masking#

Modern-day privacy regulations, like GDPR and CCPA, consider a dataset to be anonymous, if none of the contained records can "reasonably" be re-identified, i.e. be linked to a natural person or a household. Given that, it is of critical importance to understand how re-identification works, and how it continues to evolve thanks to technological advancements (as is e.g. explicitly required by GDPR recital 26).

There used to be a time, not that long ago, where the masking of direct identifiers, like full names or social security numbers, was deemed to be sufficient to "anonymize" a dataset (see here for a more thorough historical perspective). But it is the simple composition of any of the remaining attributes that allows for the instant re-identification of individual subjects. While

masking increases the effort to re-identify manually, and thus might look like an appropriate measure, it doesn't make it any more difficult for computer-assisted attacks. It's as simple as making a basic database query to successfully single out individuals within a huge sea of data.

One might even argue that pseudonymization techniques like masking and transformations are harmful, as it instills a false sense of security, leading organizations to risky data sharing practices. Due to an absence of direct identifiers, some individuals without privacy training, might wrongly assume that a redacted dataset is well protected, and share or process accordingly. **Security, that is assumed to protect whereas it does not, is the worst possible kind**, as it leads an organization to lower its guard**.**

But aside from lack of knowledge, there is certainly also an intentional ignorance of the problem, that can be encountered if privacy runs counter to commercial interest. Particularly by data brokers, organizations that resell insufficiently anonymized personal data, like mobility or browsing behavior to third parties. They bet on data protection authorities not enforcing the law, and/or on the broader public not caring enough, as they presumably lack the technical expertise. But one can tell that times are changing, if the New York Times, the Guardian, as well as your favorite Late Night host start to pick up the subject.

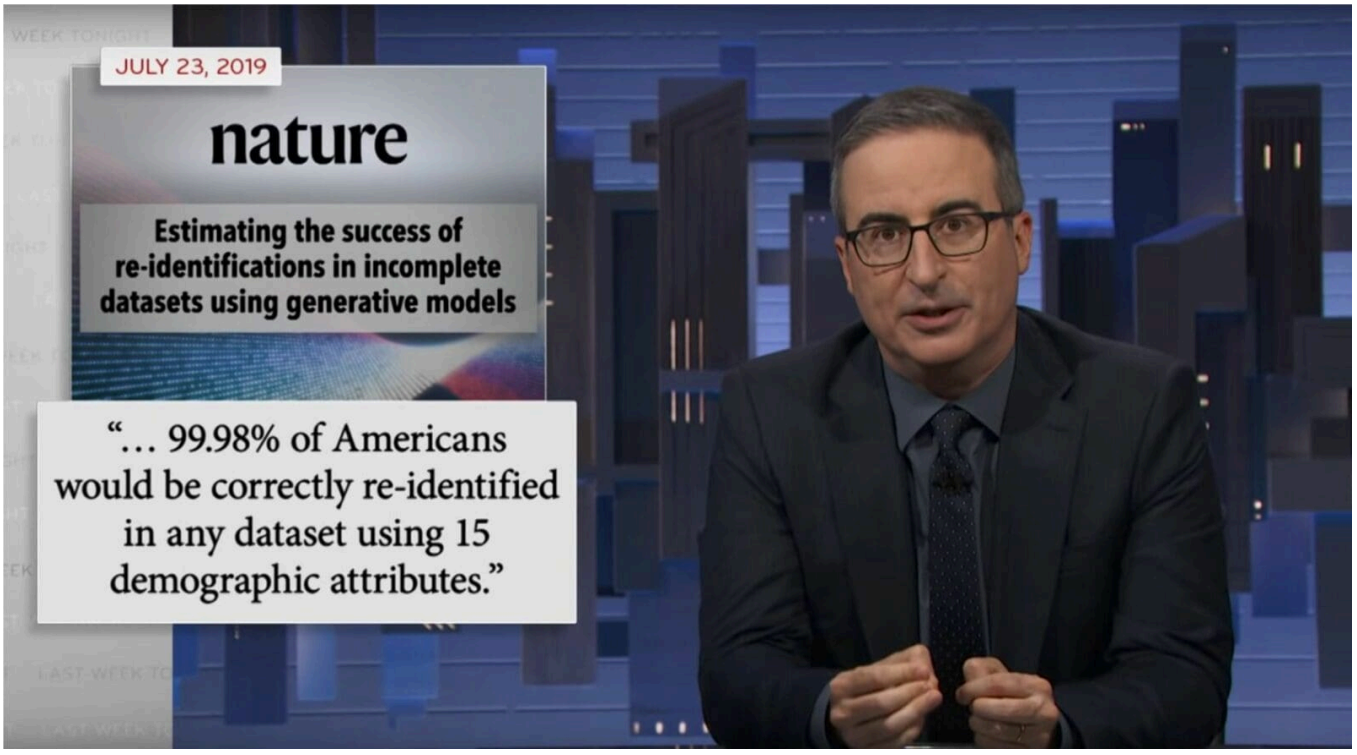

Figure 1. John Oliver explaining Linkage Attacks to his audience.

The well-established risk of linkage attacks#

The previously described type of re-identification is also known as a linkage attack. **Linkage attacks** work by linking a not-yet-identified dataset (eg. a database of supposedly anonymous medical health records) with some easier-to-obtain auxiliary information on specific individuals (e.g. the day and time that a politician gave birth). The attack is then simply performed by looking for overlapping matches between the common attributes of these two sources of information. Once such a match is found, the direct identifiers can be attributed to the

supposedly anonymous data records. In the previously stated example, finding a subject that gave birth at the same date and time as the politician, would then allow to attribute all the other medical records of that subject to the named politician - even though no direct identifiers were contained in the accessed database. Anyone with a basic knowledge of data querying techniques can perform such a “hack”, thus it is certainly “reasonably” likely to be performed by a malicious actor.

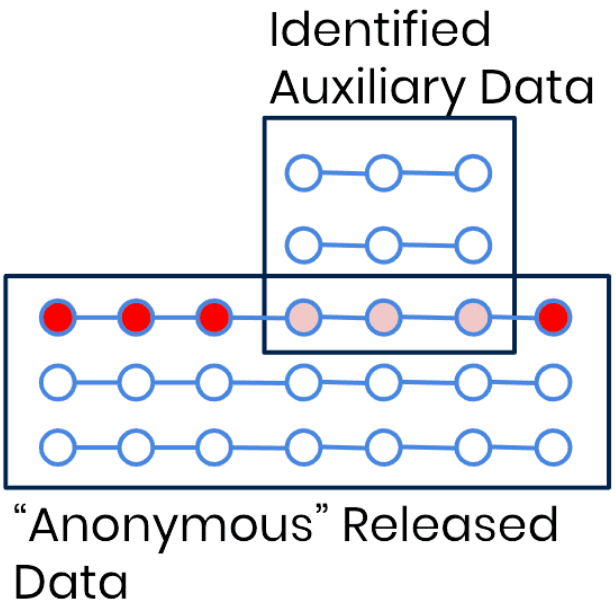

Figure 2. Linkage Attacks rely on an overlap of the data points of a released dataset, and some identified auxiliary data.

But linkage attacks are by far not only a concern for politicians and other prominent individuals in your customer database. They are similarly easy to perform on people like you and me. Other prominent examples of this type of attack include the re-identification of NY taxi trips, the re-identification of telco location data, the re-identification of credit card transactions, the re-identification of browsing data, the re-identification of health care records, and so forth. Also when turning towards the prominent case of re-identified Netflix users, we see a type of linkage attack being deployed. There the notable difference is, that Netflix had actually tried to prevent attacks by not only removing all user attributes, but also by adding random noise to obfuscate single records. However, as it turned out, these were all still ineffective, and a linkage attack based on fuzzy matches could be easily performed.

The new rise of powerful profiling attacks#

Enter a new breed of even more capable privacy attacks, that leverage AI to re-identify individuals based on their behavioral patterns: **profiling attacks**. While conceptually it has been known that these types of profiling attacks are possible, their feasibility and ease of implementation has only recently been demonstrated in peer-reviewed papers. Firstly, and most prominently, by a group of leading privacy researchers, including Yves-Alexandre de Montjoye, from the Imperial College London in their recent Nature paper. There they showcase how to successfully re-identify call data records purely based on the implicit relationships

between subjects, i.e. on the graph topology. Secondly, joint research by the Vienna University of Economics and Business and MOSTLY AI, demonstrated the applicability of the approach in their paper on re-identifying browsing patterns.

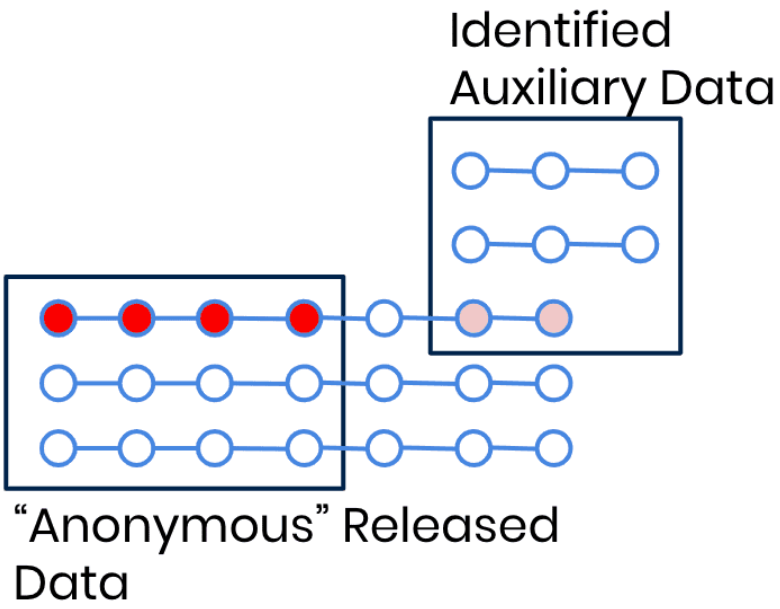

Figure 3. Profiling Attacks do NOT require an overlap of data points between a released dataset, and some identified auxiliary data.

The basic idea is simple, and borrows from modern-day face recognition algorithms. An AI model is trained specifically for the re-identification of subjects, by tasking it to correctly match a randomly selected anchor sample (e.g., an image of Arnold Schwarzenegger) with any of two alternative samples, whereas only one stemmed from the same subject (i.e., another image of Arnold, plus one from a different actor). See Figure 4 for a basic illustration of the concept - for faces, for signatures, and for browsing behavior. In all of these applications the model has to learn to extract the characteristic traits, the uniquely identifying patterns, the “identifying fingerprint” of a data record, while disregarding any other irrelevant information. That characteristic information can then be distilled from any new data in the form of a numeric vector, which then allows to define a distance measure between records of individual subjects. Equipped with that, the profiling attack itself is subsequently as simple as looking for the nearest neighbor of the identified auxiliary data record within the not-yet-identified database.

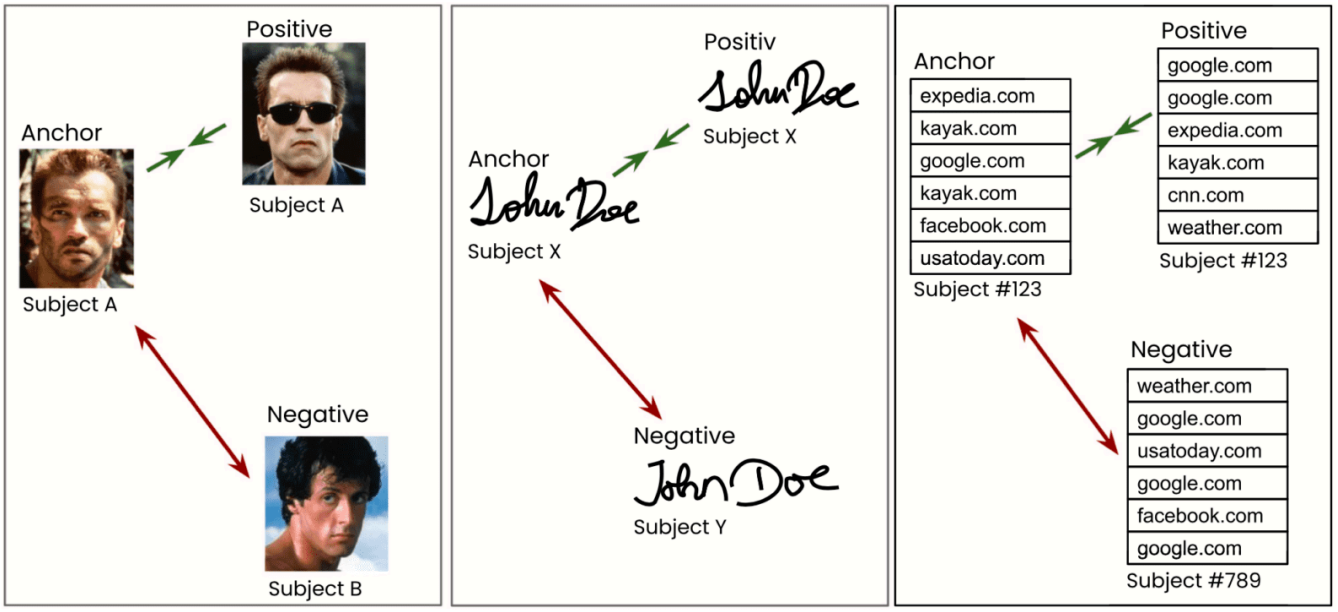

Figure 4. AI-based Re-Identification via Triplet-Loss Learning

What is truly remarkable and has a significant impact on the scope of privacy regulations is the efficiency of this methodology. Even though neither geographic, nor temporal, nor subject-level information, nor any overlapping event data have been available, the researchers were able to successfully re-identify the majority of subjects with a generic, domain-agnostic approach. One that works for re-identifying faces, signatures, as well as any sequence of tabular data. The authors further demonstrated the robustness of the method. Crețu et al. showed that the characteristic relations within call data records remained stable across several months, thus allowing re-identification based on data collected at a significantly later stage, casting major concerns on current data retention policies. And Vamosi et al., on the other hand, showed the robustness towards data perturbations. Even in cases where a third of the data points were completely randomly substituted, the re-identification algorithm found the correct match 27% of the time in a pool of thousands of candidates. Thus, the AI-based re-identification is shown to be highly robust against noise. If we expand the search to find matches within the Top 10 or Top 100 nearest neighbors, the success rate goes up significantly . This also means that just a single additional, seemingly innocuous data point - like age or zip code - will likely result in a perfect match once combined with the power of a profiling attack.

Synthetic data is immune to AI-based re-identification attacks#

The three basic techniques applied by legacy anonymization solutions are 1) the removal of attributes, 2) the generalization of attributes, and 3) the obfuscation or transformation of attributes. However, by now we have arrived in an era where dozens, hundreds, if not thousands of data points are being gathered for each and every individual which together result in these unique digital fingerprints that make it ridiculously easy for AI to find matching behavioral patterns. The more attributes of an individual are captured, the more it stands out in today's high-dimensional data spaces. And it is due to this mathematical law of high dimensions, that any of these legacy anonymization methods fail to offer protection against linkage and profiling attacks unless they destroy almost the entirety of the contained information.

Thus, leading organizations, that recognize the business value of customer trust, stop the risky practice of transferring actual production data into non-production environments. The data of a customer shall ideally only be used for serving that actual customer. For all other purposes they start to break the susceptible 1:1 link to actual data subjects, and **adopt statistically representative synthetic data at scale**.

Yet, as we've also demonstrated before, synthetic data is not automatically private by design. It needs to be properly empirically vetted. The distance measure from the newly introduced AI-based profiling attacks now provides one of the strongest possible assessments of the privacy of synthetic behavioral data. And with that, it is shown that synthetic data by MOSTLY AI - thanks to its range of in-built privacy mechanisms - is truly privacy-preserving. And thus fully anonymous under GDPR, CCPA and in the strictest possible sense.

Hence, the news is out: The time for legacy anonymization is up and privacy-preserving synthetic data is the future. If you are ready to embark on that future, don't hesitate to contact us, and we are happy to onboard you to MOSTLY AI - the leader in structured synthetic data.

Credits: The research collaboration between WU Wien and MOSTLY AI is supported by the "ICT of the Future" funding programme of the Austrian Federal Ministry for Climate Action, Environment, Energy, Mobility, Innovation and Technology.